

The 12 Audit Commandments

Framework v1.0.0 · Evidence before approval

Audit Steps investigate. Engineering Standards structure. Business Rules protect product invariants. Release Gates decide readiness.

1	Map the real flow and its threats	Actor → API → database → webhook/job → provider/storage → final state; every trust boundary named.
2	One trusted owner per critical state	Payment, plan, role, approval and ownership come from server records.
3	Backend validation is law	Client, server, schema and async inputs compared; drift fixed or explicitly justified.
4	Every protected action checks authority	Server checks authentication, role, plan and persisted resource ownership; denials produce no writes.
5	Privacy and minor safety fail closed	Missing identity, age, consent or access proof never grants private data or messaging access.
6	Thin routes; shared policy and transport	Wrappers delegate; shared helpers and apiclient/ own reusable logic and networking; state stays narrow.
7	Trusted payment confirmation only	Signed provider evidence controls entitlements; success UI confirms backend state.
8	Async work survives replay and replicas	Durable dedupe, transactions and shared coordination preserve state through retries and reversals.
9	Navigation and UI fail safely	Links validate parameters; loading/error/empty states, double-submit guards and accessible recovery work.
10	Caches never preserve revoked access	Identity, block, role and payment changes invalidate affected data; authority is rechecked.
11	Every finding needs proof; every fix verification	Reproduction, files, expected/actual results, risk, tests and redacted audit evidence are attached.
12	Ship observable, testable and reversible changes	Relevant checks pass; alerts, migration order, rollback triggers and ownership are documented.

Unchecked is not passed. Missing evidence stays unresolved. Critical/High failed gates block release; scans alone cannot prove behavioral security.

Full rules: docs/AUDIT_FRAMEWORK.md · Finding template: templates/AUDIT_REPORT.md